SYSTEM VULNERABILITY ASSESSEMENT TEST 2 SOLUTION

Question ONE (1)

1.
- **Identification of weaknesses**: Tools scan endpoints to detect potential security flaws, helping priorities remediation efforts based on severity and exploitability.
- **Automated Scanning**: Continuous monitoring and automated scans provide real time insights, reducing the risks of exposure from new vulnerabilities introduced into the network.
- **Integration with remediation tools**: many tools integrate with patch management solutions for streamlined remediation processes, minimizing delays in addressing vulnerabilities.
- **Comprehensive Reporting**: detailed reports assists in compliance and internal audits, outlining vulnerabilities, affected systems, and recommended actions.

2. **Type of Assessments**
   - **Application Assessments**: To determine vulnerabilities within the web applications in an organization.
   - **Network Assessments**: Review procedures and policies to protect against unauthorized access.
   - **Database Assessments**: Discover configuration issues and unprotected data, and other vulnerabilities within an infrastructure.
   - **Host Assessment**: Reveal vulnerabilities in critical severs that could impact operations and security if not properly tested and protected.
3. **Risks analysis** focusses on causes and direct consequences, while **vulnerability analysis** also considers primary and secondary consequences for the environment
4. **Vulnerability tools**

i. OpenVAS for All Systems
- Comprehensive scanning tool
- Covers web apps, servers, networks, OS, VMs, and databases
- Provides risk assessments and recommendations for action

ii. SolarWinds for Network Errors
- Focuses on network configuration and error detection
- Identifies misconfigurations and hidden risks
- Monitors and scans automatically, including cloud storage
- Provides recommendations and detailed reports

iii. Nikto2 for Web Applications
- Open-source tool for web server vulnerability detection
- No risk assessment or recommendations provided
- Users must decide how to handle detected vulnerabilities

iv. Nexpose for New Vulnerabilities
- - Free, open-source scanning tool for web apps, devices, and networks
- - Updated daily with the latest vulnerabilities
- - Categorizes vulnerabilities by risk level for prioritization

QUESTION TWO(2)

1.

i. Agent-Based Architecture
- Deploys software agents on target systems to gather information and perform scans
- - Examples: Qualys Cloud Agent, Tenable.io Vulnerability Management

ii. Agentless Architecture
- - Scans systems remotely without software installation
- - Uses internet protocols like SSH, WMI, and APIs
- - Examples: Nessus, Rapid7 InsightVM

iii. Cloud-Based Architecture:
- - Vulnerability tools hosted in the cloud that provide centralized management and reporting.
- - Can be agent-based, agentless, or both
- - Examples: Tenable.io, Qualys Cloud Platform, Rapid7 InsightVM

iv. Monolithic Architecture:
- - uses Single tool for risk calculation
- - Difficult to maintain and adapt to new threats

v. Multi-Source Integration:
- Combines results from multiple tools for a unified security view
- Enhances overall security understanding

2. **Agent-Based Architecture**- Deploys software agents on target systems to gather information and perform scans. While **Agentless Architecture**- Scans systems remotely without software installation and without any agents.
3.

AGENT – BASED ADVANTAGES

- **Device credential requirements**: Agent – based scanners are designed to circumvent the need for credentials as the agents are installed directly on a device.
- **No IP limitations**: Agent – based scanning is not limited by IP addresses. Assets using dynamic addressing or that are located off iste behind private subnets are still accessible with agent based scanning as they connect back to the servers.
- **BYOD support**: The increasing use of personal devices for corporate usage creates legitimate security concerns for organisations. Having agents installed provides the data on a device's security, such as if the device is fully patched. This intelligence can help to enforce corporate security policies.

AGENT – BASED DISADVANTAGES

- **Operating system dependency**: Agents must be compatible with various operating systems, which can complicate deployment across diverse environments
- **Resource consumption**: Agents may consume system resources potentially, affecting the performance of the host systems they monitor
- **Network complexity issues**: agents require consistent connectivity to communicate with central servers, which can be problematic in remote or dynamic environments.

AGENTLESS ADVATANGES

- **Wide coverage**: Various network devices, including those not compatible with agent based solutions such as routers and IoT devices.
- **Reduced administrative burden**: No need for ongoing agent maintenance and updates, which can streamline operations
- No operating system dependance: Works across different operating systems, making it more flexible in diverse environments

AGENTLESS DISADVATANGES

- **Network dependency**: Requires a consistent network connection, making remote or disconnected devices inaccessible.
- **Limited depth of scanning**: lacks the detailed visibility that agent based solutions provide as it cannot access the operating system.
- **Use cases**: Commonly used in environments where devices are predominantly on corporate networks, allowing for comprehensive network analysis without the complexity of agent management.

QUESTION THREE(3)

1. Vulnerability Management Lifecycle is a systematic process that organizations use to identify, assess, prioritize, and remediate vulnerabilities in their systems
2. ▪ Vulnerability Management Lifecycle involves the following;
   - Planning and Prework: Establishing a detailed plan for managing vulnerabilities, including such things like understanding the IT environment and defining objectives.
   - Asset Discovery and Vulnerability Assessment: Identifying and cataloging assets to determine where vulnerabilities may exist.
   - Prioritization: Ranking identified vulnerabilities based on severity, potential impact, and business context to focus on remediation efforts effectively.
   - Remediation Mitigation: Addressing the vulnerabilities through patches, configuration, changes or other severity measures
   - Validation and Monitoring: Verifying that remediation efforts were successful and continuously monitoring for new vulnerabilities.
   - Reporting and improvement: Documenting findings and refining processes based on lessons learned to enhance future vulnerability management efforts
3. **Improving security posture**

   ▪ By continuously identifying and addressing vulnerabilities, organizations can enhance their overall security posture. This helps protect sensitive data, critical systems, and infrastructure from potential attacks.

   Maintaining steady operations: Without a proper vulnerability management strategy, a cyber attack could cripple the organizations IT systems. Regular identification and management of vulnerabilities ensures that the systems is running smoothly without disruptions or shutdowns.

   Regulation Compliance: Your IT systems need to comply with data protection regulations. Failure to comply can result in substantial penalties and harm to one reputation. Many organizations have regulations and standards that mandate the implementation of vulnerability

management program such as PCI DSS, HIPAA, and NIST. Adhering to the vulnerability management lifecycle helps organizations maintain compliance and avoid penalties.

4. Air-gapping is physically isolating a critical network component from the overall network or from the internet.
    i. Minimizes attacker surface, by physically separating a system from external networks, air-gapping reduces the potential for attackers to exploit vulnerabilities
    ii. Prevents Malware spread,air-gapping helps protect critical systems from the spread of malware attacks
    iii. Protection from Zero-day exploits, air-gapped systems are less exposed to zero-day vulnerabilities as they cannot be reached via the internet or connected networks.

QUESTION FOUR(4)

1. **Attack vector (AV**)-assess the conditions necessary for an attacker to exploit the vulnerability.
2.
    i. **Base Metrics**: This metrics in the CVSS represents the intrinsic characteristics of a vulnerabilities that are constant over time and across user environments.
    ii. **Temporal Metrics** - CVSS Temporal Metrics assess the time – dependent aspects of a vulnerability's exploitability, reflecting how the risk associated with a vulnerability can change over time. In other words, they change over the lifetime of a vulnerability.
    iii. **Environmental Metrics**-CVSS Environmental Metrics allow organisations to customize the severity score of a vulnerability based on specific contextual factors relevant to their environment.
3.

- **Low (0.0 – 3.9**): Minimum risk, often requiring specific conditions for exploitation.
- **Medium (4.0 – 6.9)**: Moderate risk: Vulnerabilities are more common and easier to exploit but typically do not lead to severe consequences
- **High (7.0 – 8.9) High Risk**: Significantly threats that may allow unauthorized access or control over systems.
- **Critical (9.0 – 10.0) Over alert**: Extremely dangerous vulnerabilities that can lead to widespread exploitation and sever impacts, such as data loss or system takeover or even system downtime.

QUESTION FIVE

1.
    - **Passive vulnerability analysis** involves monitoring network traffic to identify potential security weaknesses, without actively interacting with a probing target system.
    - **Active vulnerability** involves actively scanning a network, interacting with the system to detect and identify vulnerabilities by executing a series of tests in real time.
2. **Difference between internal and External scanners**
    - **Location**: Internal scanners operate within the organization's network, assessing internal systems, while external scanners simulate attacks from outside the network, targeting public – facing assets

- **Objective**: Internal scanners focus on identifying vulnerabilities that could be exploited by insiders or attackers who have breached the perimeter. External scans aim to uncover vulnerabilities that external attackers could exploit.
- **Proactivity vs. Reactivity**: External scans are proactive, identifying potential entry points for attackers. Internal scans are more reactive, addressing vulnerabilities that already exist within the network.
- **Scope**: Internal scans provide a deeper analysis of network assets, whereas external scans evaluate the security of exposed services and ports.
- **Use cases**: Internal scans are crucial for patch management and compliance, while external scans protect against a wide range of external threats.

3. **ADVANTAGES OF PASSIVE VULNERABILITY ANALYSIS**
   - Monitor in use operating systems
   - Monitor various software and their versions to see what other services are available and running
4. **DISADVANTAGES OF PASSIVE VULNERABILITY ANALYSIS**
   - It limits the amount of information you may collect therefore getting an incomplete picture of your vulnerability status since it does not interact with the client server.
   - Much as passives scanners might provide us with information, they are incapable of acting to fix the weaknesses identified. The IT security team must assess each weakness or vulnerability and take the necessary actions to remediate or mitigate it
5. **ADVANTAGES OF ACTIVE VULNERABILITY ANALYSIS**
   - Constant vigilance to keep threat actors out. These tools provide critical information about devices such as device name, IP address, and any more detailed configuration including the following
   - Device make and model
   - Type of installed software apps
6. **DISADVANTAGES OF ACTIVE VULNERABILITY ANALYSIS**
   - usually programmed to focus on a specific area or to prevent particular situations such as employees using external media on the organization devices or computers.
   - Active scanners send packets directly to network
   - Because they are labor intensive and potentially intrusive, active scanners cannot be used to monitor the entire organization network throughout the clock. Therefore, they may not be able to detect in real time new network assets in an organization's footprint. Consequently, the vulnerabilities in these systems can remain undiscovered for some time, leaving the door open for malicious actors or professionals.